

KNT 智能合约安全审计报告

项目: Knights-dapp / KNTAllInOne

报告日期: 2026-05-19

审计对象 当前工作区智能合约、部署脚本、迁移脚本、测试脚本	核心合约 contracts/KNTAllInOneUpgradeable.sol , contracts/KNTAllInOne.sol
链上核验 BSC Mainnet block 99156104	主网代理 0x4635Ca6392229a4F7D528e9a841a5ad570aAd00D
当前实现 0x557b1120A903D13573dd19840574559fCE10384D	ProxyAdmin 0xD8a03E2D61C16728e67814Cc5c1514e4d51f4e7E

本报告基于当前本地 checkout 和只读链上核验生成。工作区在审计时存在未提交修改与新增文件，因此结论对应的是当前文件状态，而不是某个干净 Git commit。审计未执行破坏性操作，也未修改合约代码。

结论摘要

未发现无需权限即可直接盗取全部 KNT 或任意外部 ERC20 的典型漏洞；但项目的安全边界高度依赖 Owner/Admin/Manager/Keeper 和 ProxyAdmin 私钥安全。当前最高风险集中在迁移锁仓资金未隔离、keeper 可直接销毁用户余额/调减 LP 记账、以及 Admin 与 Owner 权限边界过宽。

严重级别	数量	说明
Critical	0	未发现无需权限的直接全量资产盗取路径。
High	2	迁移/奖励资金池隔离不足；Keeper 可直接破坏用户余额或 LP 记账。
Medium	6	治理权限、价格输入、外部 swap、奖励更新循环、升级运维等风险。
Low	3	实现合约初始化、ERC20 approve 体验、初始化参数校验等低风险项。
Info	3	中心化假设、自动扫描限制、源码验证状态。

验证结果

项目	结果	证据
Hardhat 编译	通过	npm run compile , 输出 Nothing to compile

本地测试	通过	npm run test:local , 16 passing
升级版本地脚本	通过	npm run test:knt:upgradeable:local , 状态 PASS
奖励/税费本地脚本	通过	npm run test:knt:rewards:local , 状态 PASS
字节码体积	接近上限	KNTAllInOneUpgradeable 为 24282 bytes, 距离 24576 bytes 仅约 294 bytes
Slither / Solhint	未运行	当前环境未安装 slither 与 solhint

链上状态核验

字段	值
Proxy	0x4635Ca6392229a4F7D528e9a841a5ad570aAd00D
Implementation	0x557b1120A903D13573dd19840574559fCE10384D
Owner	0xAC25dA7FdEEeAdf2943EBF505Fa9739CBD111bD8
ProxyAdmin Owner	0xAC25dA7FdEEeAdf2943EBF505Fa9739CBD111bD8
Reward Pool	0.0 KNT
Contract KNT Balance	0.0 KNT
Reward Period	600 seconds
Node Count	328

发现明细

High H-01 迁移锁仓与奖励发放共用合约余额，且迁移头寸未自动托管资金

位置： KNTAllInOneUpgradeable.sol:646-663, 1087-1095, 585-599

问题： mintMigration 只记录 MigrationPosition，不会从管理员转入 KNT，也不会增加专门的迁移储备。keeperClaimMigrations 与普通奖励发放都只检查 _freeBalance()，而 _freeBalance() 等于合约 KNT 余额，没有扣除未释放迁移债务、奖励池债务或燃烧队列债务。

影响： 如果后续把迁移 KNT 打入合约，奖励分发或燃烧队列可能先消耗这部分余额；如果未提前注资，迁移 claim 会直接停在 _freeBalance() < amount。本次只读核验显示当前主网合约 KNT 余额与 rewardPool 均为 0。

建议： 为迁移释放建立独立储备变量，例如 migrationReservedKnt；创建迁移头寸时强制转入或锁定对应 KNT；奖励发放使用 availableRewardBalance = balance - migrationReserved - otherReserved；增加“迁移储备充足率”测试和链上监控。

High H-02 Keeper 可无用户签名销毁用户 KNT 或调减用户 LP 记账

位置： KNTAllInOneUpgradeable.sol:522-580

问题： keeperBurnFrom 可直接销毁任意非合约、非 AMM 地址的 KNT；keeperReduceUserLp 可直接减少用户的 depositAmount、lpValueUsdt 和 power。合约虽然提供带 sourceTxHash/sourceLogIndex 的去重版本，但无 source 的版本仍可直接调用。

影响： Keeper 私钥泄露、误授权或后台逻辑错误会造成用户余额损失、LP 权益减少、节点资格变化和奖励权重下降。该设计符合当前无用户 UI、后台辅助操作模型，但它是实质性中心化托管风险。

建议： 生产环境禁用或移除无 source 版本；保留只接受链上来源 ID 的函数；为 keeper 操作增加每日限额、批次审计日志、延迟执行或多签确认；Admin 后台必须展示待执行明细并支持回滚/补偿流程。

Medium M-01 Admin 与 Owner 权限边界过宽

位置： KNTAllInOneUpgradeable.sol:229-240, 319-323, 709-787

问题： onlyOwner 实际调用 _isAdminOrOwner，因此 Admin 可以执行 transferOwnership。Admin 还能设置 Admin、Manager、关键钱包等。测试也明确覆盖了“Admin 拥有 ownership-transfer 权限”。

影响： Admin 密钥等同于协议所有权密钥。若 Admin 被盗，攻击者可接管 owner，重配钱包、路由、keeper、AMM pair 等参数。

建议： 恢复真正的 onlyOwner 与 onlyAdminOrOwner 分层；transferOwnership、setAdmin、关键路由/钱包修改建议走 ProxyAdmin owner 或多签；给 Manager/Keeper 单独做最小权限。

Medium M-02 公开 settleSell 接受调用者自报价格参数

位置： KNTAllInOneUpgradeable.sol:616-643

问题： settleSell 是公开函数，调用者传入 currentValueUsdt、priceNowUsdt_ 和 price24hAgoUsdt_ 参与利润税和下跌税计算。

影响： 如果后台或财务流程把 SellSettled 事件当作有效结算凭证，用户可通过低报价格降低税费。即便当前主要卖出路径已由 AMM 自动触发，保留该公开入口仍增加误用面。

建议： 若仍需人工结算，应改为 onlyKeeperOrAbove 并使用合约内最新价格；若不再需要，建议移除或暂停该入口。

Medium M-03 税费兑换使用零滑点保护

位置： KNTAllInOneUpgradeable.sol:1292-1307

问题： _swapKntToLabubu 调用 Pancake router 时 amountOutMin 固定为 0，deadline 使用当前区块时间。

影响： 税费兑换可能被三明治或低流动性价格影响，导致基金会/生态钱包收到极少 LABUBU；如果路由流动性异常，用户卖出也可能被税费兑换路径拖垮。

建议： 使用 keeper 更新的最小输出、TWAP/报价容忍区间，或把税费 KNT 先入库再由后台批量兑换；卖出交易内不要执行无保护兑换。

Medium M-04 Keeper 可直接影响价格税与排放参数

位置： KNTAllInOneUpgradeable.sol:733-743，1242-1278

问题： keeperUpdateGlobalLpValue 与 keeperUpdateKntPrices 无上下限、无时效性校验、无多源报价校验。卖出税计算依赖这些价格，日排放也依赖全局 LP 值。

影响： 错误或恶意 keeper 可提高/降低税费、改变排放节奏，甚至使卖出交易因为总税费过高而失败。

建议： 价格与 LP 值应增加最大变动幅度、更新时间窗口、多签确认或链上 TWAP；卖出税应拒绝过期价格，并对 dump tax 设置业务上限。

Medium M-05 奖励更新循环可能在长时间无人维护后变成 gas 阻塞点

位置： KNTAllInOneUpgradeable.sol:798-803，1028-1049，1099-1115

问题： rewardPeriodSeconds 可降至 10 分钟，当前主网也是 600 秒。_updatePool 按未更新周期循环，_touchPower 也按用户未触达周期循环。

影响： 若 keeper 长时间未调用更新，后续一次性补账可能超过 gas 限制，导致奖励发放、存款处理或用户结算卡住。

建议： 改为批量 catch-up，例如每次最多处理 N 个周期；保存指数化累计因子，避免逐周期循环；后台设置“超过 M 个周期未更新”报警。

Medium M-06 升级与源码验证流程仍是主要运维风险

位置： scripts/upgrade-knt-upgradeable-bsc-mainnet.cjs，deployments/bscMainnet/knt-upgradeable-mainnet.json

问题： 部署记录中 contractVerification.enabled=false，源码验证关闭；合约未使用 OpenZeppelin upgradeable storage gap，当前实现字节码 24282 bytes，接近 BSC/EVM 24576 bytes 上限。

影响： 外部审查难以确认链上源码；未来升级容易因字节码体积或存储布局变化失败。虽然升级脚本会校验 ProxyAdmin owner 和实现槽，但缺少自动化存储布局 diff 是持续风险。

建议： 上线后立即做 BscScan 验证；每次升级前输出 storage layout diff；保留 append-only 存储策略；为字节码体积设置 CI 阈值，例如超过 24200 bytes 即阻塞。

Low L-01 实现合约可被直接初始化

位置： KNTAllInOneUpgradeable.sol:223-288

问题： 合约没有构造函数禁用实现合约初始化。代理部署时会通过 initData 初始化代理存储，但实现合约本身仍可能被外部账户初始化。

影响： 通常不会影响代理资产，但会制造一个“看似 KNT”的实现合约状态，误转资产到实现地址时会增加救援难度。

建议： 采用 OpenZeppelin Initializable 并在实现构造函数中禁用初始化，或在部署后立即初始化实现合约到不可用 owner。

Low L-02 ERC20 approve 存在标准 allowance 竞态体验问题

位置：KNTAllInOneUpgradeable.sol:326-330 , 1383-1392

问题：approve 直接覆盖 allowance，没有 increaseAllowance / decreaseAllowance 辅助函数。

影响：与标准 ERC20 approve 竞态相同，用户在修改非零 allowance 时可能被 spender 抢跑使用旧额度。

建议：前端要求先置零再授权；合约可补充 increase/decrease allowance。

Low L-03 初始化未强制校验 router/token 参数非零

位置：KNTAllInOneUpgradeable.sol:260-288

问题：initialize 只校验 owner、foundation、dexSettlement，未校验 router、USDT、LABUBU。虽然后续 _processUsdtDeposit 会检查配置，但部署期错误不会第一时间失败。

影响：错误初始化会导致存款路径不可用，必须依赖后续 manager 修正。

建议：初始化阶段即校验关键地址，或明确允许先空配置并在部署脚本中强制二次检查。

正向安全点

- 主要外部资金流使用 SafeERC20。
- processUsdtDeposit 使用 processedUsdtDeposits 防重复处理。
- 带 source 的 keeper 操作使用 processedKeeperActions 防重复执行。
- AMM sell 自动结算路径已在本地测试覆盖，包括利润税、下跌税和成本消耗。
- 主网升级脚本会校验 ProxyAdmin 地址、ProxyAdmin owner 和 ERC1967 implementation slot。

修复优先级

优先级	行动	原因
P0	隔离迁移储备与奖励可用余额；补充迁移 claim 资金充足性测试。	避免未来迁移释放无法兑付或被奖励消耗。
P0	生产环境移除或限制无 source 的 keeper 销毁/调减函数。	降低 keeper 私钥或后台错误带来的用户资产损害。
P1	拆分 Owner/Admin/Manager/Keeper 权限，关键操作迁移到多签。	降低单一 Admin 密钥接管协议的风险。
P1	关闭公开 settleSell 或改为 keeper-only 且使用内部价格。	避免事件被误用为低税结算凭证。
P1	为价格、LP、税费兑换加入限价/时效/变动幅度约束。	减少 keeper 输入错误和 MEV 损耗。
P2	上线 BscScan 源码验证、storage layout diff、字节码体积 CI 阈值。	提升后续升级可审计性和可部署性。

限制说明

- 本报告是代码审计与只读链上核验，不等同于形式化验证。

- 未运行 Slither/Solhint, 因为当前环境没有安装这些工具。
- 未进行主网交易模拟或私钥操作。
- 由于工作区有未提交改动, 建议在修复后基于固定 commit 重新生成最终版审计报告。

Generated by Codex on 2026-05-19 from local repository C:\Users\Administrator\Documents\GitHub\Knights-dapp .